Stoquify Platform Hardening Execution Ledger — 2026-07-28

Execution boundary

The program was executed against the current dirty filesystem. No reset, clean, destructive Prisma operation, production mutation, external-provider mutation, secret rotation, migration deployment or production release was performed. The complete program cannot be finished safely in one uncommitted workspace run because the tenant database boundary, schema migrations, provider contracts, external evidence, authenticated browser smoke and rollback drills are prerequisites.

Skills used

- `001-aqstoqflow-program-orchestrator`: selected the active containment chunk and enforced stop conditions.
- `002-aqstoqflow-control-plane`: governed tenant, authorization, origin, audit and maker-checker invariants.
- `aqstoqflow-gap-plan-orchestrator`: classified work as containment, structural correction, blocked external or design-only.
- `007-aqstoqflow-pos-ledger-controls`: constrained POS containment to a pre-transaction denial.
- `011-aqstoqflow-purchasing-ap-controls`: preserved canonical purchase approval and segregation evidence.
- `aqstoqflow-access-boundary-hardener`: informed static origin/access hardening; the previously completed receipt boundary was not reopened.

Some originally referenced prerequisite files were absent at their historical `what-next/` paths. Located copies under `docs/prompts/skills`, `docs/domains/accounting-close` and `docs/planning` were read instead. The supplied prompt attachment itself ends inside its baseline command code block; the complete immediately preceding hardening specification governed the execution.

Implemented slices

INC-002 — purchase-order approval

Status: **verified remediated for the identified bulk path**.

- Generic bulk `APPROVED` is denied before service execution in the action.
- Service independently denies bulk `APPROVED` before opening a transaction.
- The previous `approvedAt`-only generic write was removed.
- Safe cancellation remains available.
- Canonical actor-aware approval remains unchanged.

Changed: purchase-order action/service and their focused tests.

Residual: inventory any future/direct write capable of setting PO status `APPROVED`; append-only transition history remains a structural follow-up.

INC-003 — store-credit tender

Status: **partially remediated through containment**.

- `commitPOSSale` rejects any `STORE_CREDIT` tender immediately after schema parsing and before `db.$transaction`.
- Test asserts no sale, stock, customer, drawer, payment, audit, business-event, posting, receipt or delivery effects occur.

Changed: POS service and its existing focused test file. The file contained substantial pre-existing user changes; only the containment helper/call and one test belong to this program.

Residual: the authoritative store-credit instrument ledger, reserve/consume/reverse lifecycle, reconciliation and rollout migration are not implemented.

INC-007 — trusted origins

Status: **verified remediated at static application configuration level**.

- Removed trust derived from Host, X-Forwarded-Host and X-Forwarded-Proto.
- BetterAuth now receives normalized configured HTTP/HTTPS origins only.
- Added normalization, invalid-scheme, deduplication and spoof-exclusion tests.

Residual: live reverse-proxy integration and production configuration validation remain unverified; localhost origins remain configured for compatibility.

Command ledger

Command	Result	Relevant output	Attribution
`npm test -- --runInBand lib/security/__tests__/trusted-origins.test.ts`	failed	2/3 passed; global Request unavailable	Test harness/test implementation, not runtime control
Same trusted-origin command after fixture repair	passed	1 suite, 3/3	Static origin policy
`npm test -- --runInBand services/purchase-order/__tests__/purchase-order.service.test.ts actions/purchaseOrderWorkflow/__tests__/purchaseOrderSystemAction.test.ts`	passed	2 suites, 14/14	PO containment
`npm test -- --runInBand services/pos/__tests__/pos.service.test.ts`	passed	1 suite, 14/14	POS containment/current POS slice
Combined security + purchase test command	passed	3 suites, 17/17	Combined containment
`npm run prisma:validate`	passed	Schema valid	Static schema only
`npm run typecheck`	passed	Exit 0	Current dirty tree at that instant

Command	Result	Relevant output	Attribution
`npm run service:boundary:fail`	passed	0 active violations	Static scanned boundaries
`npm run hard-delete:fail`	passed	0 unsafe; 8 classified allowed	Static scan
`npm run workflow:assurance:release-gate`	passed	38/38, 11/11, 2/2	Static; did not run assurance checks
Runtime assurance, policy composite, build	skipped	See matrix	Risk/time/scope; no pass claim
Provider/statutory/webhook/production verification	blocked	No authorized access/evidence	External dependency

Files changed by implementation

- `lib/auth.ts`
- `lib/security/trusted-origins.ts`
- `lib/security/__tests__/trusted-origins.test.ts`
- `actions/purchaseOrderWorkflow/purchaseOrderSystemAction.ts`
- `actions/purchaseOrderWorkflow/__tests__/purchaseOrderSystemAction.test.ts`
- `services/purchase-order/purchase-order.service.ts`
- `services/purchase-order/__tests__/purchase-order.service.test.ts`
- `services/pos/pos.service.ts`
- `services/pos/__tests__/pos.service.test.ts`

Gates

Passed: architecture/service boundary, focused containment tests, Prisma validation, TypeScript, hard-delete, static workflow-assurance gate.

Blocked: DB-scoped tenant enforcement, transactional critical audit, token migration, offline actor migration, provider lifecycle, concurrency fixes, projection convergence, production observability, migration-history repair, statutory approval and clean-candidate release evidence.

Next required numbered skill

`002-aqstoqflow-control-plane` remains active until ADR-0002 is formally implemented or superseded with migration and rollback proof. Do not advance the structural financial program past containment while this high tenant invariant is unresolved.